Técnicas de cracking

El sniffing pasivo

El sniffing pasivo (también conocido como sniffer) es una técnica de ciberseguridad que se utiliza para analizar el tráfico de red sin interactuar con él. Los sniffers pasivos capturan los paquetes de datos que se transmiten a través de una red y los analizan para buscar información útil o sensible.

Este tipo de sniffing se lleva a cabo sin que los usuarios de la red se den cuenta de que se está capturando su tráfico. Los sniffers pasivos no afectan el tráfico de red ni lo alteran de ninguna manera, solo lo observan.

Los sniffers pasivos se utilizan con fines legítimos, como el análisis de tráfico de red para identificar problemas de rendimiento o seguridad, pero también pueden ser utilizados con fines malintencionados, como la obtención de información confidencial, como contraseñas o información de tarjetas de crédito.

Es importante proteger la red de sniffers pasivos mediante la implementación de medidas de seguridad adecuadas, como el cifrado de datos y el uso de software de detección de sniffers.

Ejemplo

Un ejemplo común de sniffing pasivo es el uso de programas como Wireshark para analizar el tráfico de red. Wireshark es un sniffer de red de código abierto que puede utilizarse para capturar paquetes de datos que se transmiten en una red.

Supongamos que un administrador de red sospecha que hay un problema de rendimiento en la red y decide utilizar Wireshark para analizar el tráfico de red. El administrador inicia Wireshark en una computadora conectada a la red y lo configura para capturar todos los paquetes de datos que se transmiten a través de ella. Wireshark captura los paquetes de datos y los presenta en una interfaz gráfica que permite al administrador analizarlos en detalle.

El administrador puede utilizar Wireshark para buscar paquetes de datos que muestren retrasos o cuellos de botella en la red. También puede utilizar Wireshark para buscar

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.

información sensible o confidencial, como contraseñas o números de tarjeta de crédito, que se estén transmitiendo sin cifrar.

Wireshark: la herramienta para el análisis de tráfico de red: https://www.wireshark.org/download.html

Video explicativo: https://www.incibe-cert.es/seminarios-web/uso-wireshark

Ejemplo de uso: https://wiki.wireshark.org/Ejemplo_VoIP_calls_spanish.md

El sniffing activo

El sniffing activo es una técnica de ciberseguridad que se utiliza para analizar y capturar el tráfico de red, al igual que el sniffing pasivo. Sin embargo, a diferencia del sniffing pasivo, el sniffing activo interactúa con el tráfico de red para obtener información adicional.

El sniffing activo se lleva a cabo mediante la introducción de paquetes de datos falsos en la red, con el objetivo de obtener respuestas que puedan revelar información sobre la red o los dispositivos conectados a ella. Estos paquetes falsos pueden ser diseñados para simular una solicitud de ping o para buscar información específica, como direcciones MAC o direcciones IP.

El sniffing activo se utiliza con fines legítimos, como el análisis de la seguridad de la red o la identificación de vulnerabilidades. Sin embargo, también puede ser utilizado con fines malintencionados, como la obtención de información confidencial o la realización de ataques de denegación de servicio (DDoS).

Es importante tener en cuenta que el sniffing activo puede ser detectado por los sistemas de seguridad de la red, y su uso ilegal puede tener graves consecuencias legales.

Ejemplo

Un ejemplo de sniffing activo es el uso de programas como Nmap para identificar los dispositivos que están conectados a una red y para obtener información sobre ellos. Nmap es una herramienta de exploración de red de código abierto que se utiliza comúnmente para la detección de dispositivos y la identificación de vulnerabilidades.

Supongamos que un administrador de red desea identificar todos los dispositivos que están conectados a una red y descubrir sus direcciones IP, direcciones MAC y puertos

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.

abiertos. El administrador puede utilizar Nmap para enviar paquetes de datos falsos a la red, solicitando información específica sobre los dispositivos que están conectados a ella.

Nmap puede enviar paquetes falsos que simulan una solicitud de ping para determinar qué dispositivos están activos en la red. También puede enviar paquetes falsos que intentan conectarse a un puerto específico en un dispositivo, con el objetivo de determinar si el puerto está abierto o cerrado.

Una vez que Nmap ha obtenido información sobre los dispositivos conectados a la red, el administrador puede utilizar esta información para realizar una evaluación de seguridad de la red y determinar si hay vulnerabilidades que necesiten ser corregidas.

El ARP poisoning

El ARP poisoning, también conocido como ARP spoofing, es un tipo de ataque de red en el que se envían paquetes ARP (Address Resolution Protocol) falsificados a un dispositivo en la red con el objetivo de redirigir su tráfico de red a otro dispositivo malintencionado en la misma red.

En una red, cada dispositivo tiene una dirección IP única y una dirección MAC única. Cuando un dispositivo necesita enviar un paquete de datos a otro dispositivo en la misma red, utiliza el protocolo ARP para traducir la dirección IP del dispositivo de destino en su dirección MAC correspondiente. El dispositivo emisor de datos envía una solicitud ARP a la red preguntando "¿Quién tiene esta dirección IP?" y el dispositivo con la dirección IP correspondiente responde con su dirección MAC.

En un ataque de ARP poisoning, un atacante envía paquetes ARP falsificados a un dispositivo de la red, diciéndole que su dirección IP corresponde a la dirección MAC del dispositivo del atacante en lugar del dispositivo real. Una vez que el dispositivo de la víctima acepta esta información falsa, comienza a enviar su tráfico de red al dispositivo del atacante en lugar del dispositivo real.

Este tipo de ataque puede permitir que el atacante intercepte, modifique o incluso bloquee el tráfico de la víctima. También puede permitir que el atacante realice ataques man-in-the-middle para robar información confidencial o realizar otros tipos de ataques.

Ejemplo

Un ejemplo de cómo se puede llevar a cabo un ataque de ARP poisoning sería el siguiente:

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.

Supongamos que hay una red local con varios dispositivos conectados, incluyendo una computadora A y una computadora B. El atacante C quiere interceptar el tráfico de red entre A y B, para lo cual decide realizar un ataque de ARP poisoning.

Para hacerlo, el atacante C envía paquetes ARP falsificados a la computadora A, diciéndole que la dirección IP de la computadora B corresponde a la dirección MAC del propio C. Cuando la computadora A recibe estos paquetes falsos, actualiza su tabla ARP local con la información falsa proporcionada por el atacante.

A partir de ese momento, cuando la computadora A necesita comunicarse con la computadora B, envía sus paquetes de datos a la dirección MAC del atacante C, creyendo que se trata de la dirección MAC de la computadora B. El atacante C puede entonces interceptar, modificar o bloquear el tráfico de red entre A y B según su objetivo.

Ejemplo de uso de ettercap: https://informatyc.wordpress.com/2018/04/14/manual-de-uso-para-la-aplicacion-ettercap-ataque-mitm/

https://www.bujarra.com/uso-de-ettercap/

Video de ejemplo:

- Medrano Jonathan. (26 de enero de 2022). Qué es "envenenamiento de ARP" - Tutorial de Ettercap y Wireshark. YouTube. https://www.youtube.com/watch?v=GDd80_9meYs&ab_channel=JonathanMedrano
- Yax Joel. (6 de agosto de 2016). Sniffer - Kali Linux 2.0 Actualizado. YouTube. https://www.youtube.com/watch?v=gsRV3WAscnQ&ab_channel=JoelYax

Denegación de servicio (DDoS)

Un ataque de denegación de servicio (DDoS, por sus siglas en inglés) es un tipo de ataque cibernético en el que un atacante utiliza múltiples dispositivos, como computadoras o dispositivos IoT, para inundar una red, un servidor o una aplicación con una gran cantidad de tráfico malintencionado, lo que hace que el servicio o la aplicación se vuelvan inaccesibles para los usuarios legítimos.

El objetivo de un ataque DDoS es interrumpir o deshabilitar el servicio o la aplicación en cuestión, lo que puede tener un impacto negativo en el negocio o la organización. Los ataques DDoS pueden ser lanzados desde una variedad de fuentes, como botnets, redes

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.

de dispositivos IoT comprometidos, servidores de retransmisión abiertos o computadoras infectadas con malware.

Los ataques DDoS se pueden clasificar en varias categorías, como ataques de amplificación, ataques de saturación, ataques de agotamiento de recursos y ataques de aplicación. Los ataques de amplificación implican enviar solicitudes a servidores mal configurados que responden con paquetes de datos mucho más grandes, lo que aumenta el volumen de tráfico. Los ataques de saturación implican enviar grandes cantidades de tráfico a la red o el servidor objetivo, lo que causa una sobrecarga del sistema y lo hace inaccesible. Los ataques de agotamiento de recursos implican consumir los recursos del sistema, como el ancho de banda o la memoria, para que el sistema no pueda seguir funcionando. Los ataques de aplicación se dirigen a vulnerabilidades específicas de las aplicaciones web para agotar los recursos del servidor y hacer que la aplicación sea inaccesible.

Los ataques DDoS pueden tener graves consecuencias para las organizaciones, incluyendo pérdidas financieras, daños a la reputación y pérdida de confianza de los clientes. Por lo tanto, es importante que las organizaciones estén preparadas para enfrentar los ataques DDoS y tengan planes de contingencia y medidas preventivas en su lugar.

Un **ejemplo** de cómo funciona un ataque de denegación de servicio (DDoS) podría ser el siguiente:

Supongamos que una empresa tiene un sitio web en línea que recibe muchas visitas diarias. Un atacante quiere hacer que el sitio web sea inaccesible para los usuarios legítimos, por lo que utiliza una botnet (un grupo de dispositivos infectados controlados por el atacante) para lanzar un ataque DDoS contra el sitio.

El ataque se lleva a cabo inundando el sitio web con una gran cantidad de solicitudes de conexión. Como resultado, el servidor que aloja el sitio web se sobrecarga y no puede procesar todas las solicitudes. Esto hace que el sitio web sea inaccesible para los usuarios legítimos que intentan acceder a él.

El ataque DDoS puede durar desde unos minutos hasta varias horas, dependiendo de la duración del ataque y la capacidad del servidor para resistirlo. Si el servidor no tiene medidas de protección adecuadas, el ataque puede ser efectivo y hacer que el sitio web sea inaccesible durante un período prolongado de tiempo.

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.

Algunos casos

Ataque DDoS a Dyn: en octubre de 2016, un ataque DDoS afectó a los servidores DNS de Dyn, una empresa de servicios de Internet. El ataque afectó a los sitios web y servicios de empresas como Twitter, Spotify, Reddit y The New York Times, entre otros, haciendo que fueran inaccesibles para los usuarios durante varias horas.

Ataque DDoS a GitHub: en marzo de 2015, GitHub, una plataforma de desarrollo de software, fue víctima de un ataque DDoS masivo que duró varios días. El ataque fue llevado a cabo por una botnet que utilizó solicitudes falsificadas para inundar los servidores de GitHub con tráfico malintencionado.

Ataque DDoS a BBC: en diciembre de 2015, la BBC fue víctima de un ataque DDoS que interrumpió sus servicios en línea. El ataque fue llevado a cabo por un grupo de hackers conocido como New World Hacking, que afirmó estar actuando en represalia por la cobertura de la BBC de ISIS.

Ataque DDoS a Estonia: en abril de 2007, Estonia, un pequeño país del Báltico, sufrió un ataque DDoS masivo que afectó a los servicios en línea del gobierno, bancos, empresas y medios de comunicación. El ataque fue llevado a cabo en medio de tensiones políticas con Rusia y se cree que fue orquestado por grupos pro-rusos.

Casos recientes de DDOS:

https://www.cloudflare.com/es-es/learning/ddos/famous-ddos-attacks/

https://computerhoy.com/listas/tecnologia/mayores-ataques-ddos-historia-internet-555187

https://www.elmundo.es/tecnologia/2022/08/18/62fea606fdddff808c8b45ab.html

Existen varias medidas que se pueden tomar para prevenir un ataque de denegación de servicio (DDoS). Algunas de ellas son:

- **Configurar firewalls:** los firewalls pueden ayudar a prevenir algunos tipos de ataques DDoS al bloquear el tráfico malicioso antes de que llegue a la red protegida.
- **Utilizar servicios de mitigación de DDoS:** los servicios de mitigación de DDoS pueden detectar y mitigar automáticamente los ataques DDoS en tiempo real, protegiendo la red de la organización.
- **Limitar la tasa de solicitudes:** configurar límites de velocidad en las solicitudes de tráfico entrante puede reducir el impacto de los ataques DDoS.

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.

- **Utilizar sistemas de detección de intrusos (IDS) e *intrusion prevention systems* (IPS):** estos sistemas pueden detectar y prevenir algunos tipos de ataques DDoS.
- **Actualizar software y firmware:** mantener el software y el firmware actualizado en los dispositivos de red puede ayudar a prevenir vulnerabilidades que pueden ser explotadas por atacantes.
- **Utilizar sistemas de autenticación sólidos:** los sistemas de autenticación sólidos, como el multi-factor authentication (MFA), pueden ayudar a prevenir ataques de fuerza bruta y otros tipos de ataques que pueden ser utilizados en un ataque DDoS.
- **Planificar un plan de contingencia:** tener un plan de contingencia en su lugar puede ayudar a minimizar el impacto de un ataque DDoS en caso de que ocurra.

Estas son solo algunas de las medidas que se pueden tomar para prevenir un ataque de denegación de servicio (DDoS). Es importante que las organizaciones trabajen con expertos en seguridad informática para desarrollar una estrategia de seguridad sólida que incluya medidas de protección contra ataques DDoS.

Videos:

- ComputerHoy.com (24 oct 2015). ¿Qué es un ataque DDoS? YouTube. https://www.youtube.com/watch?v=7xGdz5Li9Sw&ab_channel=ComputerHoy.com
- AlbertoLopez TECH TIPS [Alberto López]. (2 de noviembre de 2021). ¿Qué es un ataque DDoS? ¿Cómo funciona? YouTube. https://www.youtube.com/watch?v=Yp7zthdaL48&ab_channel=AlbertoLopezTECHTIPS
- https://www.youtube.com/watch?v=gxL4Mf41qK0&ab_channel=Pywa
- Alonso, José María. (1 de mayo de 2018). ElevenPaths Talks 4: Un poco DDoS y herramientas para detener los ataques. YouTube. https://www.youtube.com/watch?v=BE5wEYz-dkg&ab_channel=JoseMariaAlonso

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.